INFORME TÉCNICO DE RESOLUCIÓN CTF

Cracking de contraseñas

John the Ripper y Hashcat

Integrante: Felipe Segura

Asignatura: Ciberseguridad Avanzada

Docente: Rodrigo Ledezma

Fecha: 3 de noviembre de 2026

Resultado documentado

Reto 1 completado: Panda123 abre secreto.zip. Reto 2 no completado durante la ejecución; la guía proporciona una respuesta de referencia.

Elaborado a partir de la resolución y las evidencias disponibles del desafío.

2. Introducción

La actividad contiene dos retos: recuperar la contraseña de secreto.zip con John the Ripper y buscar una contraseña a partir de h2.txt con Hashcat mediante una máscara. Se busca documentar el procedimiento y distinguir los resultados obtenidos de las respuestas incluidas en la guía.

3. Análisis inicial

Se recibieron un ZIP protegido, un hash y una política de ocho caracteres: una mayúscula, cinco minúsculas y dos dígitos. La estrategia fue usar diccionario para el ZIP y ataque de máscara para el hash. El prefijo 6 de h2.txt corresponde al formato SHA-512 crypt usado con el modo 1800.

4. Herramientas utilizadas

zip2john y John the Ripper: convierten el ZIP al formato de entrada de John y prueban candidatos del diccionario. Permitieron recuperar Panda123.

Hashcat: realiza el ataque de máscara; se probó con CPU en Kali y con una RTX 3070 en Windows para mejorar el rendimiento.

rockyou.txt y PoCL: el diccionario del sistema aportó candidatos válidos; PoCL habilitó el uso de la CPU en Kali.

5. Metodología de resolución

Reto 1. Extracción y ataque de diccionario

```
zip2john /home/kali/Desktop/secreto.zip > hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
john --show hash.txt
```

--wordlist especifica el diccionario y --show muestra la contraseña recuperada. El archivo llamado rockyou.txt del escritorio contenía un hash, por lo que se sustituyó por el diccionario de Kali. Se recuperó Panda123 y se abrió nota.txt.

Reto 2. Ataque de máscara

```
.\hashcat.exe -O -m 1800 -a 3 h2.txt "?u?l?l?l?l?l?d?d"
```

-m 1800 selecciona SHA-512 crypt; -a 3 activa el ataque de máscara; -O usa kernels optimizados con sus límites de longitud. ?u representa una mayúscula, ?l una minúscula y ?d un dígito. La máscara contempla 26^6 × 10^2 = 30.891.577.600 candidatos.

En Kali se instaló PoCL y se utilizó -O por limitaciones de memoria. Luego se probó Windows con una RTX 3070. La resolución registra una estimación que pasó de aproximadamente un año a un día, sin conservar registros de velocidad. La búsqueda se detuvo sin recuperar la contraseña del reto 2.

6. Evidencias

La comprobación de solo lectura del ZIP confirmó que Panda123 permite abrir nota.txt. El contenido del archivo es:

```
Archivo: secreto.zip / nota.txt
Contraseña validada: Panda123
Contenido: Nota confidencial del curso de ciberseguridad.
```

Esta comprobación valida la contraseña, pero no sustituye una captura de la sesión original de John. No se encontraron capturas ni registros de ejecución de John o Hashcat en la carpeta.

7. Uso de pistas

La guía recomienda zip2john, rockyou y la máscara de la política. La resolución también reconoce apoyo de ChatGPT para interpretar errores, corregir comandos y configurar las herramientas. El PDF Desafio.pdf incluye páginas de solución; se distinguen del trabajo ejecutado.

8. Obtención de la FLAG o resultado

Reto 1: resultado obtenido y validado, Panda123. El archivo abierto no contiene una FLAG con formato especial; contiene una nota del curso.

Reto 2: no resuelto durante el ataque documentado. La página 5 de Desafio.pdf declara Zebras42 como respuesta de referencia. Se registra su procedencia sin atribuirla a un resultado de Hashcat.

9. Análisis del proceso

Las dificultades fueron usar un archivo incorrecto como diccionario y configurar un motor de cómputo compatible. Corregir el diccionario resolvió el primer reto. La GPU redujo la estimación del segundo, pero una política conocida todavía produce miles de millones de candidatos y el tiempo depende del hash y del hardware.

10. Análisis ético

Se trabajó con archivos entregados para el laboratorio. Estas técnicas se deben limitar a auditorías y recuperación autorizadas; los hashes y las contraseñas obtenidas deben tratarse como información sensible.

11. Conclusiones

John permitió recuperar y validar la contraseña del ZIP. Hashcat mostró cómo una máscara reduce la búsqueda, aunque el segundo ataque quedó incompleto. Una política predecible no reemplaza una contraseña larga y difícil de adivinar.

Fuentes y archivos de respaldo

Pauta_Resolucion_Desafio_CTF.docx: estructura del informe.

Desafio HashCat-JohnTheRipper/resolucion.md: procedimiento y estado de ambos retos.

Desafio.pdf, páginas 2 a 5: objetivos, pistas y soluciones de referencia.

secreto.zip y h2.txt: archivos proporcionados para el laboratorio.